Week 3: Linux Logs, Sysmon, auditd and Snort Setup

Theory Notes, Developing Basic Understanding in SOC

Question 5. Describe the structure of a Snort rule. Break down the rule header and rule options with examples. Include a table of common rule options (msg, sid, rev, flags, flow, threshold, classtype).

Basic structure

A Snort rule has two parts. The first is the rule header, which says what kind of traffic to look at. The second is the rule options, written inside brackets and separated by semicolons, which say what to look for and how to report it.

```
action protocol src_ip src_port direction dst_ip dst_port (option1; option2; ...)
```

Here is an example from my lab.

```
alert tcp any any -> $HOME_NET 22 (msg:"SSH Connection Attempt"; sid:1000002; rev:1;)
```

Rule header

Part	Meaning	Example
Action	What Snort should do when the rule matches	alert, log, pass, drop, reject
Protocol	The type of traffic	tcp, udp, icmp, ip
Source IP and port	Where the traffic comes from	any any, or $EXTERNAL_NET any
Direction	Which way the traffic flows	-> for one way, <> for both ways
Destination IP and port	Where the traffic is going	$HOME_NET 22

Common rule options

Option	What it does	Example
msg	The text shown in the alert, so the analyst knows what happened	`msg:"ICMP Ping Detected";`
sid	A unique ID for the rule. Custom rules usually start from 1000000	`sid:1000001;`
rev	The revision number, which goes up when the rule is edited	`rev:2;`
flags	Checks the TCP flags in the packet. S stands for SYN	`flags:S;`
flow	The direction and state of the connection	`flow:to_server,established;`
threshold	Controls how often the rule should alert	`threshold:type threshold, track by_src, count 20, seconds 1;`
classtype	Places the alert in a category with a priority	`classtype:attempted-recon;`
content	Looks for specific text or bytes in the data	`content:"/etc/passwd";`

Option	What it does	Example
reference	Adds a link to outside information, such as an ATT&CK page	`reference:url,attack.mitre.org/techniques/T1046/;`
metadata	Adds extra tags, such as the MITRE technique	`metadata:mitre_technique T1046;`

Understanding the Nmap SYN scan rule

```
alert tcp $EXTERNAL_NET any -> $HOME_NET any (msg:"MITRE T1046 - Nmap SYN Port Scan
Detected"; flags:S; threshold:type threshold, track by_src, count 20, seconds 1;
classtype:attempted-recon; metadata:mitre_technique T1046;
reference:url,attack.mitre.org/techniques/T1046/; sid:1000004; rev:1;)
```

- The header looks at TCP traffic coming from outside networks towards any host and any port in my network.
- `flags:S` matches packets with the SYN flag, which is how a half open scan begins.
- `threshold` makes Snort alert only when one source sends 20 SYN packets within a second, so a normal single connection is ignored.
- `classtype`, `metadata` and `reference` give the category and connect the rule to the MITRE technique.